**Day33_MFA_SessionSecurity**

**Q1 — MFA Fundamentals [2 Marks]**

Multi-Factor Authentication (MFA) is a security method that requires users to provide two or more independent authentication factors to verify their identity.

Example: Logging in using a password and a security key.

**Q2 — 2FA vs MFA [2 Marks]**

- 2FA (Two-Factor Authentication): requires exactly two different authentication factors.
- MFA (Multi-Factor Authentication): requires two or more different authentication factors.

**Q3 — Password Security [3 Marks]**

1. Use long and complex passwords.
2. Use unique passwords for different accounts.
3. Avoid using personal information such as names or birthdays.
4. Never share passwords with others.
5. Enable MFA for additional account protection.
6. Change passwords immediately if they are suspected of being compromised.

**Q4 — Password Storage [3 Marks]**

- **Password Hashing:** Converts a password into a fixed-length hash value using a one-way hashing algorithm.
- **Salt:** A unique random value added to a password before hashing to make attacks using precomputed hash tables more difficult.
- **Plaintext Storage:** Storing passwords in readable form is dangerous because attackers who access the database can directly obtain users' passwords.

**Day33_MFA_SessionSecurity**

**Q5 — Session Management [3 Marks]**

A web session maintains a user's authenticated state across multiple HTTP requests because HTTP is stateless.

A session identifier is a unique value assigned to a user after finishing authentication. The browser sends it with subsequent requests so the server can recognise the user without requiring them to log in again for every page.

**Q6 — Secure Cookies [3 Marks]**

The three important cookie attributes are:

- **Secure**: Ensures the cookie is sent only over HTTPS connections.
- **HttpOnly**: Prevents JavaScript from directly accessing the cookie, helping reduce cookie theft through XSS attacks.
- **SameSite**: Controls whether cookies are sent with cross-site requests, helping protect against Cross-Site Request Forgery (CSRF).

**Q7 — Session Lifecycle [2 Marks]**

- **Idle Timeout:** Automatically expires a session after a defined period of user's inactivity.
- **Absolute Timeout:** Expires a session after a fixed maximum lifetime, regardless of user's activity.
- **Session Invalidation on Logout:** Destroys or invalidates the authenticated session on the server when the user logs out.

**Q8 — Practical Lab [2 Marks]**

The PortSwigger lab demonstrated an MFA bypass vulnerability. After logging in with the victim's credentials, changing the URL from /login to /my-account allowed access to the victim's account without completing MFA verification.

Prevention:

- Enforce MFA verification on the server side.
- Do not grant access to protected pages until MFA is completed.
- Maintain separate authentication states for password verification and MFA completion.
- Invalidate incomplete authentication sessions appropriately.

**Day33_MFA_SessionSecurity**

**Evidence of Completion:**

